Demo sécurité Docker

Docker est isolé de l hôte => ce qui se passe dans docker reste dans docker

~~Docker est isolé de l hôte => ce qui se passe dans docker reste dans docker~~

Il est possible de sortir : container escape

RULE #1 - Do not expose the Docker daemon socket (OWASP)

/var/run/docker.sock

(même en readonly)

nginx-proxy (500 M)

nginx-proxy = nginx + docker-gen

docker-gen doit parler à l'API Docker donc on lui donne
/var/run/docker.sock:/tmp/docker.sock**:ro**

possède le param -notify

le pouvoir secret de docker.sock

Si un processus peut ouvrir le socket et envoyer des requêtes HTTP Docker API valides, il peut demander au daemon de créer des conteneurs

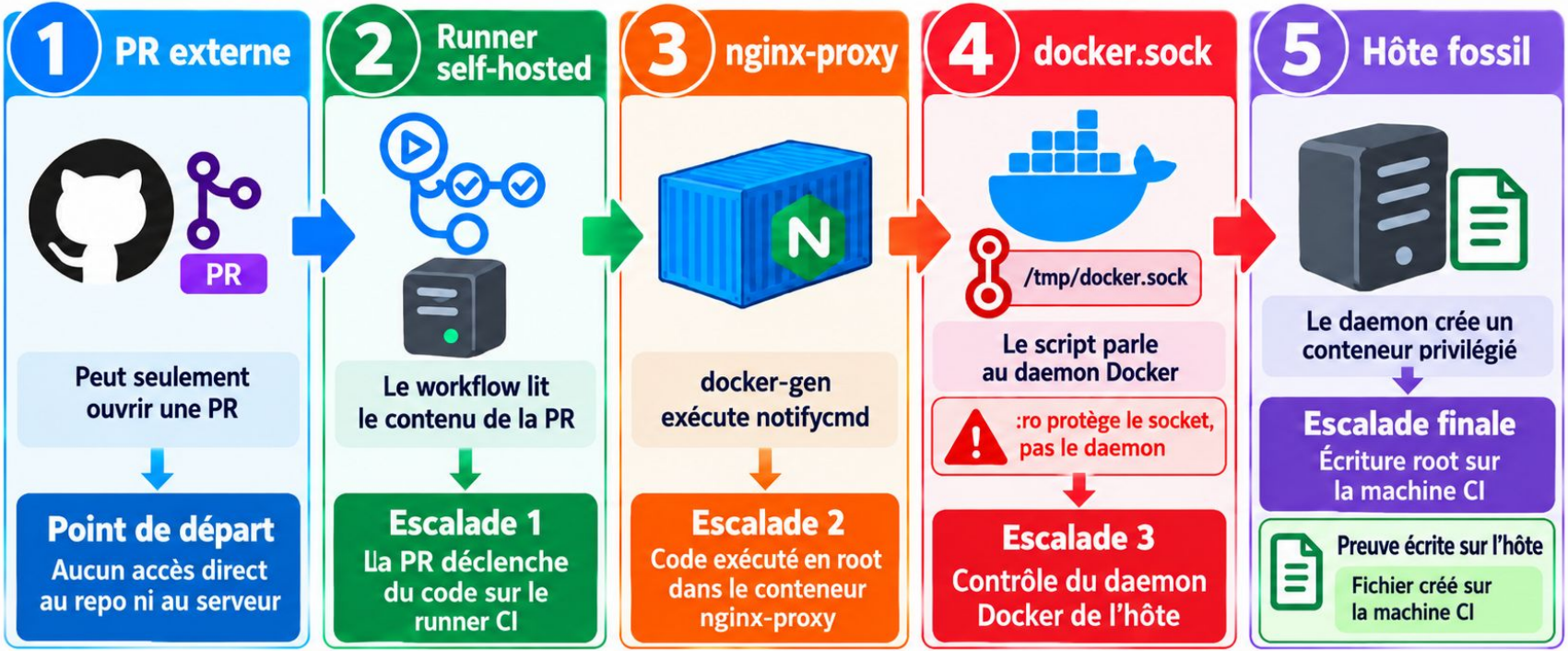
le pouvoir secret de docker.sock

Si un processus peut ouvrir le socket et envoyer des requêtes HTTP Docker API valides, il peut demander au daemon de créer des conteneurs

et donc exécuter du code avec les permissions du docker engine : root

De la PR à l'écriture root sur la machine CI

Escalade progressive via workflow self-hosted, nginx-proxy et docker.sock



Exécuter du code dans un conteneur qui possède docker.sock revient à piloter Docker sur l'hôte.